

DRAFT UNTIL ISSUED

BOARD REPORT · FY26 PRIVACY AND SECURITY REVIEW

भारत डेटा प्राइवेट लिमिटेड

Privacy and information security gap assessment

India DPDPA 2023

ISO 27001 2022

ASSESSMENT PERIOD

01 Apr 2026 to 30 Jun 2026

EVIDENCE CUT-OFF

15 Jul 2026

VERSION

v2 · 28 Sep 2026

SNAPSHOT

5f2c9e1a

Contents

01	Assessment overview Scope, approach and how to read the ratings	3
02	Executive summary Posture by framework, domain status, risk profile and decisions	5
03	Key observations The 10 highest-ranked approved findings	9
04	Remediation roadmap Initiatives by horizon, owners and change since the last report	12
05	Annexure Methodology, requirement and evidence registers, Statement of Applicability	17

We assessed 120 requirements across 2 frameworks against evidence received up to 15 Jul 2026.

Scope



India DPDPA 2023

India DPDPA: 41 requirements in scope

41
REQUIREMENTS



ISO 27001 2022

ISO 27001: 79 requirements in scope (Physical Controls excluded: single cloud-hosted office)

79
REQUIREMENTS

ASSESSMENT PERIOD

01 Apr 2026 to 30 Jun 2026

EVIDENCE CUT-OFF

15 Jul 2026

11

documents reviewed

120

requirements
concluded

10

key observations

8

initiatives

4

open evidence
requests

Approach

1

Collect evidence

Documents, questionnaire responses and walkthrough notes received up to the evidence cut-off, each stored by version with its SHA-256.

2

Assess and approve

For each in-scope requirement an outcome is proposed with cited evidence. A consultant reviews the evidence and individually approves, edits or rejects every outcome.

3

Score and report

Scores are computed in code from approved outcomes only, per framework, and never combined. Findings, owners and dates are set by the consultant with management.

This document constitutes an evidence-based compliance gap assessment. It is not a formal compliance audit and does not constitute legal advice. Findings are based on documents submitted for review and information disclosed by the organization's representatives, and every conclusion was individually approved by a consultant. These conclusions reflect the evidence considered up to the evidence cut-off stated above.

Outcomes are concluded per requirement; risk is set on each gap; remediation is rated on three dimensions.

Requirement outcome

Compliant	The requirement is met and supported by evidence.
Partially compliant	The requirement is met in part; a gap remains.
Non-compliant	The requirement is not met.
Insufficient evidence	The evidence does not support a conclusion either way. Excluded from scores, not treated as a failure.
Not applicable	The requirement does not apply within the assessed scope.

Risk level of a gap

Critical Material regulatory or breach exposure; act now	High Significant exposure; act this quarter	Medium Moderate exposure; plan within six months	Low Limited exposure; address in normal course
--	---	--	--

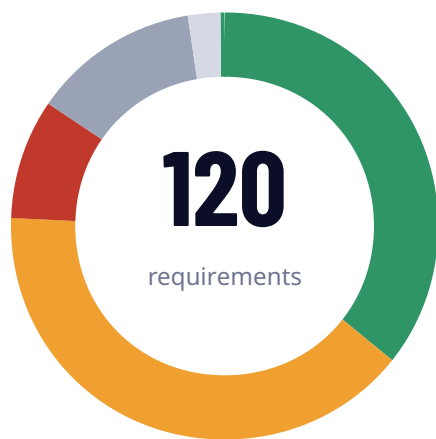
Remediation dimensions

Dimension	High	Medium	Low
Priority  Derived from the highest approved risk it closes	Critical or high gap; start within 30 days	Medium gap; schedule in 30-90 days	Low gap; review quarterly
Complexity  Consultant estimate of effort	Over 40 person-hours or cross-team change	8-40 person-hours	Under 8 person-hours
Benefit  Consultant view of risk reduction	Removes a critical or high exposure	Materially reduces exposure	Incremental improvement

Horizon and responsibility

Short term Target within 90 days of this report	Medium term 91-180 days	Long term After 180 days
Responsibility + भारत डेटा प्राइवेट लिमिटेड + Golden Advisory ++ Shared		

The organisation has a sound policy base, but several controls that protect customer data exist on paper only and are not operated. **R-03** **R-05** **R-07** The most serious exposures are consent that is unlikely to be valid, no procedure for notifying the regulator of a breach, and access rights that are never reviewed. **R-01** **R-02** **R-03** Most gaps are process gaps with clear owners, and closing access control and supplier security once addresses findings under both frameworks. **R-03** **R-04** **R-06** **R-07**



■ Compliant
 ■ Partially compliant
 ■ Non-compliant
 ■ Insufficient evidence
 ■ Not applicable

43

Compliant
36% of requirements

48

Partially compliant
40% of requirements

11

Non-compliant
9% of requirements

15

Insufficient evidence
12% of requirements

22

Critical or high gaps
of 59 gaps · 65 last period

Total requirements assessed: 120

Counts across frameworks; scores below are per framework and never combined

India DPDPA

41 requirements · 26 gaps · 5 not concluded

10

21

5

5

57%

▲ +16 pts Needs Significant Improvement

ISO 27001

79 requirements · 33 gaps · 10 not concluded

33

27

6

10

3

69%

▲ +10 pts Partially Compliant

Top three risks

Detail in section 03

R-01 Consent is collected through pre-ticked boxes

Consent obtained this way is unlikely to be valid, so processing that depends on it would lack a lawful basis once DPDPA obligations commence; this affects the full 2.1 million-customer marketing base.

R-02 No procedure to notify the Data Protection Board of a breach

A breach handled under the current plan would miss the statutory notification, which carries the highest penalty tier under the Act.

R-03 Access rights are never reviewed

Former staff and over-privileged users can reach customer data, the most common root cause of insider and credential-based breaches.

1 of 9 in-scope domains have no approved gaps; the weakest are Breach Notification (25%) and Rights of Data Principal (45%).

India DPDP Act 2023

57% · Needs Significant Improvement · 41 requirements

Obligations of Data Fiduciary · 17 req



49%

14 gaps · 8 crit/high

Rights of Data Principal · 6 req · 1 not concluded



45%

4 gaps

Special Provisions · 7 req · 1 not concluded



60%

5 gaps · 3 crit/high

Consent Management (Detailed) · 4 req · 1 not concluded



88%

1 gaps · 1 crit/high

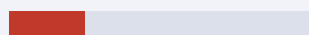
Cross-Border Data Transfer · 3 req



100%

No gaps

Breach Notification · 4 req · 2 not concluded



25%

2 gaps · 1 crit/high

ISO 27001 2022

69% · Partially Compliant · 79 requirements

Organizational Controls · 37 req · 4 not concluded



65%

18 gaps · 7 crit/high

People Controls · 8 req · 1 not concluded



60%

4 gaps

Physical Controls

Out of scope

Technological Controls · 34 req · 5 not concluded



76%

11 gaps · 2 crit/high

Domain score bars use the published rating thresholds (80% Compliant, 60% Partially compliant, 40% Needs significant improvement). Gap counts are approved non-compliant or partially compliant requirements.

59 approved gaps, 22 of them critical or high; 4 critical gaps sit in 4 domains.

CRITICAL RISK GAPS

4

WHERE THEY SIT

DPDPA · Breach Notification

1

DPDPA · Obligations of Data Fiduciary

1

ISO 27001 · Organizational Controls

1

ISO 27001 · Technological Controls

1

HIGH RISK GAPS

18

WHERE THEY SIT

DPDPA · Obligations of Data Fiduciary

7

ISO 27001 · Organizational Controls

6

DPDPA · Special Provisions

3

DPDPA · Consent Management (Detailed)

1

MEDIUM RISK GAPS

28

WHERE THEY SIT

ISO 27001 · Technological Controls

8

ISO 27001 · Organizational Controls

6

DPDPA · Obligations of Data Fiduciary

4

DPDPA · Rights of Data Principal

4

LOW RISK GAPS

9

WHERE THEY SIT

ISO 27001 · Organizational Controls

5

DPDPA · Obligations of Data Fiduciary

2

ISO 27001 · People Controls

1

ISO 27001 · Technological Controls

1

All approved gaps by risk

59

gaps

Risk	DPDPA	ISO	All
Critical	2	2	4
High	11	7	18
Medium	11	17	28
Low	2	7	9

What we are asking the board to approve, and what needs management attention now.

1 Approve funding for a consent-management platform before the May 2027 DPDPA commencement.

Recommended by Priya Sharma

2 Confirm the CISO as accountable owner for vulnerability management and set the patch SLA as a board-tracked KPI.

Recommended by Priya Sharma

Needs attention

1

overdue actions

2

actions without owner

15

not concluded

1 remediation action is past its target date (access reviews, due 15 Sep 2026).

1 action(s) on critical or high findings have no owner.

1 action has no target date.

15 requirements could not be concluded; 4 evidence requests are open.

The highest-ranked approved findings, with the risk they create and what we recommend.

+ Client + Golden Advisory ++ Shared responsibility

No.	Domain	Observation	Risk	Rating	Recommendation	Reference
R-01	+ Obligations of Data Fiduciary India DPDPA	Consent is collected through pre-ticked boxes The sign-up journey and the marketing preference centre both pre-select consent. No record links a consent to the notice the user saw.	Consent obtained this way is unlikely to be valid, so processing that depends on it would lack a lawful basis once DPDPA obligations commence; this affects the full 2.1 million-customer marketing base.	Critical	Replace pre-selected consent with an unticked, purpose-specific opt-in on every channel. Log each consent with the notice version shown, timestamp and channel, and re-collect consent for the existing marketing base before relying on it.	DPDPA Section 6(1), 6(3); Section 6; Section 6(1)
R-02	++ Breach Notification India DPDPA	No procedure to notify the Data Protection Board of a breach The incident response plan covers containment only. It names no owner, timeline or template for notifying the Board or affected individuals.	A breach handled under the current plan would miss the statutory notification, which carries the highest penalty tier under the Act.	Critical	Extend the incident response plan with a notification runbook: named decision owner, 72-hour clock, Board and data-principal templates, and an evidence log. Test it in a tabletop exercise each year.	DPDPA Section 8(6); DPDP Rules 2025 r.7(2) ISO 27001 Annex A.5.5
R-03	+ Organizational Controls ISO 27001	Access rights are never reviewed No periodic review of user access is evidenced for production systems. 14 leaver accounts were still active at the cut-off.	Former staff and over-privileged users can reach customer data, the most common root cause of insider and credential-based breaches.	Critical	Run quarterly access recertification for production and customer-data systems with manager sign-off. Disable leaver accounts within 24 hours through an HR-triggered workflow and keep review evidence.	ISO 27001 Annex A.5.18; Annex A.5.3; Annex A.5.16; Annex A.5.11
R-04	+ Technological Controls ISO 27001	No defined cadence for patching technical vulnerabilities Scans run ad hoc; 23 critical CVEs older than 90 days were open on internet-facing hosts at the cut-off.	Known, exploitable weaknesses on public systems are the leading entry point for ransomware.	Critical	Adopt patch SLAs by severity (critical 15 days, high 30 days), scan internet-facing assets weekly, and report open critical vulnerabilities to the risk committee monthly.	ISO 27001 Annex A.8.8

The highest-ranked approved findings, with the risk they create and what we recommend.

+ Client + Golden Advisory ++ Shared responsibility

No.	Domain	Observation	Risk	Rating	Recommendation	Reference
R-05	+ Obligations of Data Fiduciary India DPDP A	Customer database access is not restricted by role Encryption at rest is in place, but 41 engineers hold read access to the customer database with no role-based restriction.	Broad access raises the likelihood and scale of a personal-data breach and weakens the 'reasonable security safeguards' defence.	High	Define role-based access profiles for the customer database, remove standing engineer access, and route exceptions through time-bound, approved break-glass access with session logging.	DPDPA Section 8(5); DPDP Rules 2025 r.6(1)(a)-(b); Section 8(5) ISO 27001 Annex A.5.15; Annex A.8.3; Annex A.6.7
R-06	++ Obligations of Data Fiduciary India DPDP A	Data Processor contracts lack data-protection clauses Seven of nine processor contracts reviewed contain no security, breach-notice or deletion obligations.	The company remains liable for its processors' failures with no contractual recourse or audit right.	High	Issue a data-processing addendum covering security, breach notice within 24 hours, sub-processing, audit rights and deletion at exit, and track signature to completion.	DPDPA Section 8(2) ISO 27001 Annex A.5.19
R-07	+ Organizational Controls ISO 27001	Supplier security is not assessed before onboarding A supplier questionnaire exists but is not used; no supplier risk tiering is recorded.	Third-party compromise cannot be anticipated or contracted against.	High	Tier suppliers by data access, assess tier-1 suppliers before onboarding and annually, and record the risk decision in the supplier register.	DPDPA Section 8(2) ISO 27001 Annex A.5.19
R-08	+ Obligations of Data Fiduciary India DPDP A	Customer data is retained indefinitely The retention policy sets periods for HR records only; customer and KYC data have no retention period or deletion job.	Holding data beyond its purpose enlarges breach impact and conflicts with the storage-limitation duty.	High	Set retention periods for customer and KYC data by purpose and legal basis, and automate deletion or anonymisation at expiry with a monthly exception report.	DPDPA Section 8(7); Section 8(7); DPDP Rules 2025 r.8(3); Section 12(3) ISO 27001 Annex A.8.10

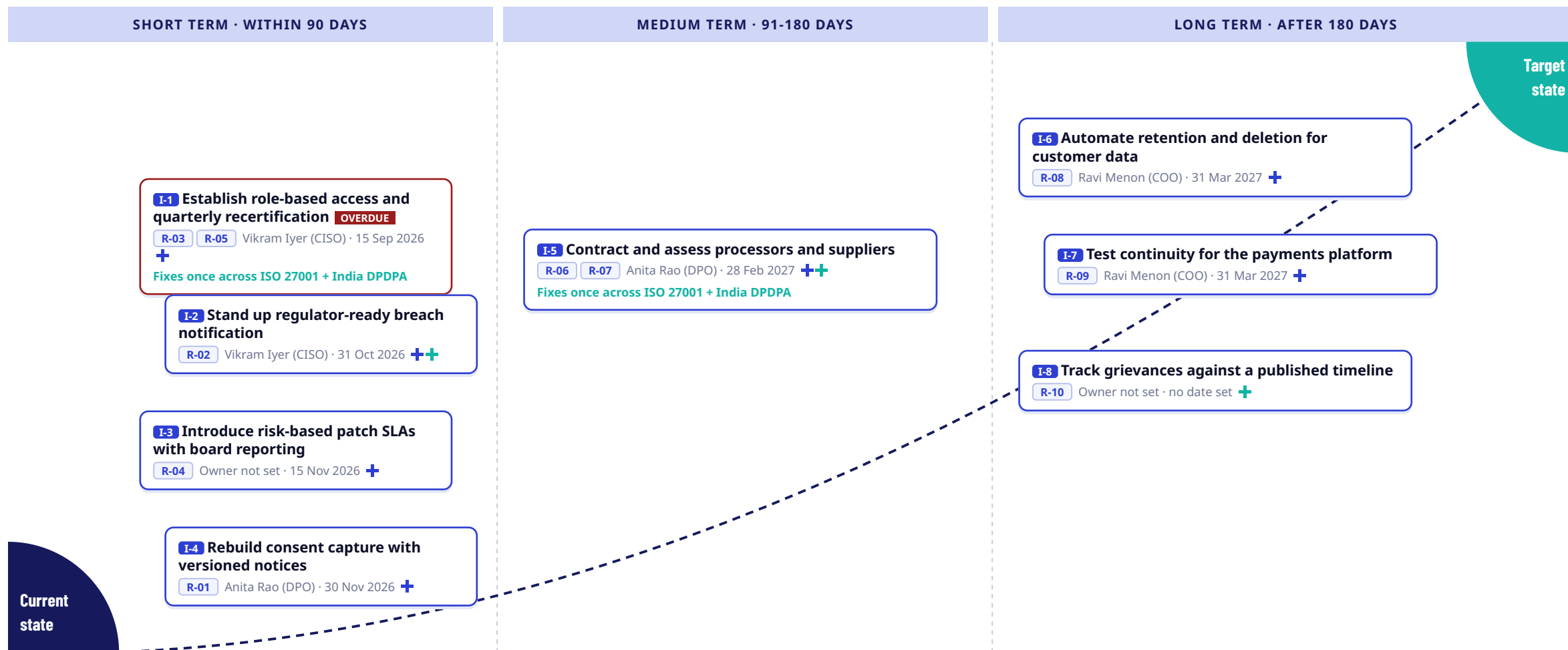
The highest-ranked approved findings, with the risk they create and what we recommend.

+ Client + Golden Advisory ++ Shared responsibility

No.	Domain	Observation	Risk	Rating	Recommendation	Reference
R-09	+ Organizational Controls ISO 27001	Business continuity plan has never been tested The BCP is approved but no test or exercise has been recorded since it was written in 2024.	Recovery times for core platforms are unknown; an outage could exceed customer contractual commitments.	Medium	Test the BCP for the payments platform against target recovery times, record the results and fix gaps found before the next test cycle.	ISO 27001 Annex A.5.30; Annex A.5.29; Annex A.8.6; Annex A.8.13
R-10	+ Rights of Data Principal India DPDPA	Grievance channel has no response timeline Grievances are received through a shared mailbox with no tracking or response-time commitment.	Unresolved complaints can be escalated to the Data Protection Board.	Medium	Publish a grievance form with ticket tracking and a 30-day response commitment, and report volumes and ageing to the DPO monthly.	DPDPA Section 13(1); Section 6(3), 8(9); DPDP Rules 2025 r.9; Section 13(2)

8 initiatives close all 10 key observations; 2 of them fix a weakness once across both frameworks.

+ Client + Golden Advisory ++ Shared **OVERDUE**



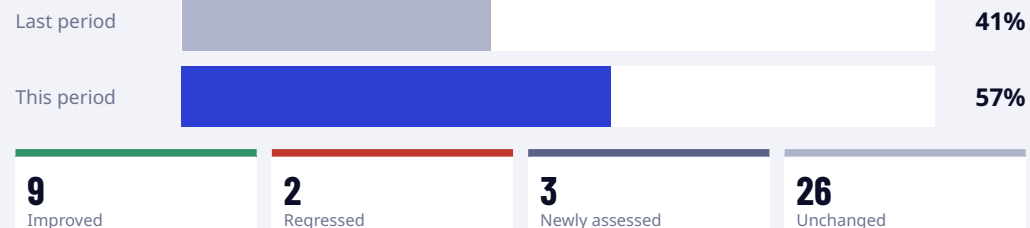
Every initiative, the observations it closes and how it rates on priority, complexity and benefit.

Ref	Initiative	Closes	Horizon	Owner	Priority	Complexity	Benefit	Actions
I-1	Establish role-based access and quarterly recertification Access control and privileged access · fix once across ISO 27001 + India DPDP	R-03 R-05	Short term 15 Sep 2026 · overdue	+ Vikram Iyer (CISO)	 High	 High	 High	A-01 Open A-02 Open
I-2	Stand up regulator-ready breach notification Incident and breach response	R-02	Short term 31 Oct 2026	++ Vikram Iyer (CISO)	 High	 Medium	 High	A-03 In progress A-04 Open
I-3	Introduce risk-based patch SLAs with board reporting Vulnerability and patch management	R-04	Short term 15 Nov 2026	+ Not set	 High	 Medium	 High	A-05 Open
I-4	Rebuild consent capture with versioned notices Consent and notice	R-01	Short term 30 Nov 2026	+ Anita Rao (DPO)	 High	 High	 High	A-06 In progress
I-5	Contract and assess processors and suppliers Third-party and processor security · fix once across ISO 27001 + India DPDP	R-06 R-07	Medium term 28 Feb 2027	++ Anita Rao (DPO)	 High	 Medium	 Medium	A-07 Open A-08 Open
I-6	Automate retention and deletion for customer data Data retention and deletion	R-08	Long term 31 Mar 2027	+ Ravi Menon (COO)	 High	 High	 Medium	A-09 Open
I-7	Test continuity for the payments platform Business continuity	R-09	Long term 31 Mar 2027	+ Ravi Menon (COO)	 Medium	 Medium	 Medium	A-10 Open
I-8	Track grievances against a published timeline Data-principal rights and grievances	R-10	Not scheduled No date set	+ Not set	 Medium	 Low	 Medium	A-11 Open

Compared with report v3 for 01 Oct 2025 to 31 Dec 2025, read from its stored document. Scores are compared within each framework only.

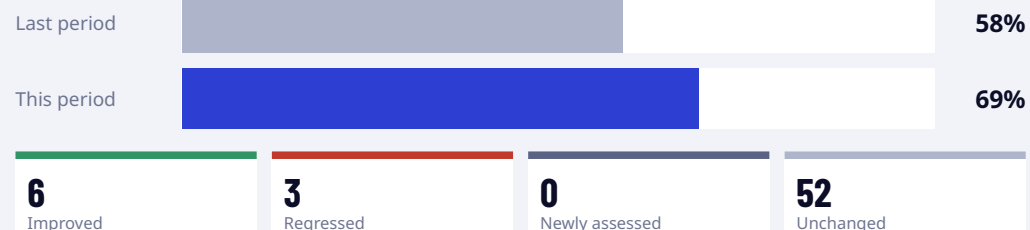
India DPDPA

▲ +16 pts



ISO 27001

▲ +10 pts



Requirements that changed outcome

Requirement	Last period	This period	
India DPDPA CH2.CONSENT.2 Itemised consent for multiple purposes	Non-Compliant	Compliant	Improved
India DPDPA CH2.CONSENT.4 Consent Manager registration and interoperability	Partially Compliant	Compliant	Improved
India DPDPA CH2.CONSENT.5 Verifiable parental consent for children's data	Non-Compliant	Compliant	Improved
ISO 27001 ISO.A5.18 Access rights	Partially Compliant	Non-Compliant	Regressed
ISO 27001 ISO.A8.8 Management of technical vulnerabilities	Partially Compliant	Non-Compliant	Regressed

Gaps identified: 65 last period, 59 this period.

15 requirements could not be concluded; they are excluded from scores, not treated as failures.

Open evidence requests (v2)

RFI-01	Consent records export for July 2026	Required
RFI-02	Cross-border transfer register and destination list	Required
RFI-03	DPIA for the loan-underwriting model	Required
RFI-04	Last two backup-restore test reports	Recommended

Not concluded, by framework

5 India DPDPA	10 ISO 27001
-------------------------------------	------------------------------------

The full list is in Annexure A2 (outcome "Insufficient evidence").

Limitations

- This assessment does not include technical penetration testing, source code review, network security assessment, or any form of independent technical verification. Where the selected framework(s) include physical or environmental controls, findings on those controls are based on disclosed information and submitted documents, not on physical inspection or testing.
- All findings reflect the information provided to the assessor at the time of the assessment. The assessor has not independently verified the accuracy or completeness of information provided. Material omissions or inaccuracies in disclosed information would affect the reliability of findings.
- For requirements rated as Non-Compliant or Partially Compliant at a Critical or High risk level, independent verification by qualified legal counsel or a certified privacy professional (for INDIA DPDPA requirements), or by a qualified information security auditor (for ISO 27001), is strongly recommended before relying on those findings for regulatory submissions, board reporting, or contractual representations.
- Most DPDPA 2023 obligations on Data Fiduciaries, and its penalty provisions, commence in mid-May 2027 (DPDP Rules 2025, G.S.R. 846(E)); findings against those obligations are a readiness assessment, not a determination of current non-compliance. Until then, obligations under the Information Technology Act, 2000, s.43A and the SPDI Rules, 2011 continue to apply and were not assessed.

Prepared and reviewed by the engagement team; the issue record lives in the version history.

PREPARED BY

Priya Sharma

Golden Advisory

Signature

REVIEWED BY

Ravi Menon

Golden Advisory

Signature

RELEASED FOR REPORTING

Priya Sharma

on 27 Sep 2026

Signature

ISSUE RECORD

Version history

Issuer, date and file SHA-256

Signature

Report version v2 · generated 28 Sep 2026 · snapshot 5f2c9e1a-4d7b-4e2a-9c3f-0b1d2e3f4a5b

Names are recorded as entered by the consultant; they are not verified sign-ins. This report is prepared solely for the use of the named organization. It should not be shared with third parties without the organization's explicit consent. Golden Advisory and the named organization are the intended recipients of this report.

05

Annexure

A1 Methodology

A2 Requirement register

A3 Evidence register

A4 Statement of Applicability summary

This assessment evaluates compliance against the following framework(s): India DPDPA, ISO 27001, across 120 in-scope requirements.

Basis of Assessment:

Each in-scope requirement receives one conclusion. The analysis engine reviews the submitted documents and questionnaire responses and proposes an outcome with cited evidence. A consultant reviews the evidence and individually approves, edits or rejects every proposal. Only individually approved conclusions appear in this report; no outcome, score or finding is produced by the AI on its own.

Outcome Definitions:

- Compliant: the requirement is met and supported by evidence
- Partially Compliant: the requirement is met in part
- Non-Compliant: the requirement is not met
- Insufficient Evidence: the evidence provided does not support a conclusion either way
- Not Applicable: the requirement does not apply within the assessed scope

Scoring Basis:

Scores are computed only from conclusions a consultant has individually approved. Each approved outcome counts as follows: Compliant 100 points, Partially Compliant 50 points, Non-Compliant 0 points. Not Applicable and Insufficient Evidence are excluded from the scoring denominator. Insufficient Evidence is not treated as Non-Compliant; the number of requirements with insufficient evidence is reported next to each framework score. Requirements excluded at scoping are not scored. A framework is scored only when every in-scope requirement has an approved conclusion. Section scores are the average of their requirement points; domain and framework scores are weighted averages using the published weights below.

Framework Structure and Weights:

- India DPDPA (2023): 41 requirements in 6 domains. Domain weights: Obligations of Data Fiduciary 30%, Rights of Data Principal 20%, Special Provisions 20%, Consent Management (Detailed) 10%, Cross-Border Data Transfer 10%, Breach Notification 10%.

- ISO 27001 (2022): 93 requirements in 4 domains. Domain weights: Organizational Controls 35%, People Controls 15%, Physical Controls 15%, Technological Controls 35%.

Requirements are referenced by clause or control identifier for each selected framework; requirement descriptions are summarised for assessment purposes and do not reproduce the source standard. Scores are computed and reported independently for each framework; no score is combined across frameworks.

Rating Thresholds:

- 80-100%: Compliant
- 60-79%: Partially Compliant
- 40-59%: Needs Significant Improvement
- 0-39%: Non-Compliant

Risk Classification:

Each gap carries the risk level (Critical, High, Medium, Low) approved by the consultant, reflecting regulatory exposure, potential penalties under INDIA DPDPA and impact on affected individuals (for INDIA DPDPA), and likely impact on the confidentiality, integrity and availability of information (for ISO 27001). Remediation priority on each gap is derived from its approved risk level.

Disclaimer:

This assessment provides guidance based on the information and evidence provided and is not legal advice. Consult qualified legal counsel for definitive compliance determinations under INDIA DPDPA. For ISO 27001, it is not a certification audit; certification decisions rest with an accredited certification body or qualified assessor.

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
DPDPA	CH2.CONSENT.1	Lawful basis for processing with free, specific, informed consent	Obligations of Data Fiduciary	● Non-Compliant	Critical	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, s.4.2, p.6
DPDPA	CH2.CONSENT.2	Itemised consent for multiple purposes	Obligations of Data Fiduciary	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.28
DPDPA	CH2.CONSENT.3	Consent withdrawal mechanism	Obligations of Data Fiduciary	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.18
DPDPA	CH2.CONSENT.4	Consent Manager registration and interoperability	Obligations of Data Fiduciary	● Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.4
DPDPA	CH2.CONSENT.5	Verifiable parental consent for children's data	Obligations of Data Fiduciary	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.28
DPDPA	CH2.NOTICE.1	Notice accompanying the consent request	Obligations of Data Fiduciary	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.20
DPDPA	CH2.NOTICE.2	Notice for previously collected data	Obligations of Data Fiduciary	● Partially Compliant	Medium	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.3
DPDPA	CH2.NOTICE.3	Notice contains contact details of DPO or grievance officer	Obligations of Data Fiduciary	● Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.6
DPDPA	CH2.PURPOSE.1	Processing only for stated purpose	Obligations of Data Fiduciary	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.5
DPDPA	CH2.PURPOSE.2	Legitimate uses without consent properly identified	Obligations of Data Fiduciary	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.5
DPDPA	CH2.MINIMIZE.1	Collection limited to what is necessary	Obligations of Data Fiduciary	● Partially Compliant	Medium	Edited · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.21
DPDPA	CH2.MINIMIZE.2	Data retention limited to purpose fulfilment	Obligations of Data Fiduciary	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	data-retention-policy.pdf v1, s.3, p.2
DPDPA	CH2.MINIMIZE.3	Retention schedule and deletion procedures	Obligations of Data Fiduciary	● Non-Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.16
DPDPA	CH2.ACCURACY.1	Data accuracy ensured for decision-making and onward disclosure	Obligations of Data Fiduciary	● Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.9
DPDPA	CH2.SECURITY.1	Reasonable security safeguards implemented	Obligations of Data Fiduciary	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.4
DPDPA	CH2.SECURITY.2	Encryption and access controls	Obligations of Data Fiduciary	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, Annex B, p.22
DPDPA	CH2.SECURITY.3	Data Processor contractual safeguards	Obligations of Data Fiduciary	● Non-Compliant	High	Approved · Priya Sharma, 24 Sep 2026	vendor-contracts-index.xlsx v2, rows 3-11
DPDPA	CH3.ACCESS.1	Summary of personal data and processing activities	Rights of Data Principal	● Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
DPDPA	CH3.CORRECT.1	Mechanism for correction and completion of data	Rights of Data Principal	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.18
DPDPA	CH3.CORRECT.2	Mechanism for erasure of personal data	Rights of Data Principal	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.17
DPDPA	CH3.GRIEVANCE.1	Grievance redressal mechanism available	Rights of Data Principal	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.26

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
DPDPA	CH3.GRIEVANCE.2	Timely response to grievances	Rights of Data Principal	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.12
DPDPA	CH3.NOMINATE.1	Nomination mechanism for death or incapacity	Rights of Data Principal	● Non-Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.4
DPDPA	CH4.CHILD.1	No tracking or behavioural monitoring of children	Special Provisions	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.24
DPDPA	CH4.CHILD.2	No processing detrimental to child's well-being	Special Provisions	● Partially Compliant	High	Edited · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.22
DPDPA	CH4.CHILD.3	Age verification mechanism	Special Provisions	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.11
DPDPA	CH4.SDF.1	Data Protection Officer (DPO) appointed	Special Provisions	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.2
DPDPA	CH4.SDF.2	Independent Data Auditor appointed	Special Provisions	● Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
DPDPA	CH4.SDF.3	Data Protection Impact Assessment (DPIA) conducted	Special Provisions	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.26
DPDPA	CH4.SDF.4	Periodic audit completed	Special Provisions	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.14
DPDPA	CM.RECORDS.1	Consent records maintained	Consent Management (Detailed)	● Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
DPDPA	CM.RECORDS.2	Fresh consent for a new or changed purpose	Consent Management (Detailed)	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.30
DPDPA	CM.GRANULAR.1	Granular consent options available	Consent Management (Detailed)	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.24
DPDPA	CM.GRANULAR.2	No consent bundling with service access	Consent Management (Detailed)	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.9
DPDPA	CB.TRANSFER.1	Data transfers only to non-restricted jurisdictions	Cross-Border Data Transfer	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.23
DPDPA	CB.TRANSFER.2	Transfers comply with s.16 restrictions and stricter sectoral law	Cross-Border Data Transfer	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.10
DPDPA	CB.TRANSFER.3	Data localisation where required	Cross-Border Data Transfer	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.21
DPDPA	BN.NOTIFY.1	Breach notification to Data Protection Board	Breach Notification	● Non-Compliant	Critical	Approved · Priya Sharma, 24 Sep 2026	incident-response-plan.docx v2, s.5, p.3
DPDPA	BN.NOTIFY.2	Breach notification to affected Data Principals	Breach Notification	● Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
DPDPA	BN.NOTIFY.3	Incident response plan documented	Breach Notification	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.16
DPDPA	BN.NOTIFY.4	Breach register maintained	Breach Notification	● Insufficient Evidence	Medium	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A5.1	Policies for information security	Organizational Controls	● Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A5.2	Information security roles and responsibilities	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.17
ISO 27001	ISO.A5.3	Segregation of duties	Organizational Controls	● Partially Compliant	Medium	Edited · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.8
ISO 27001	ISO.A5.4	Management responsibilities	Organizational Controls	● Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.5
ISO 27001	ISO.A5.5	Contact with authorities	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.13
ISO 27001	ISO.A5.6	Contact with special interest groups	Organizational Controls	● Partially Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.21
ISO 27001	ISO.A5.7	Threat intelligence	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.21
ISO 27001	ISO.A5.8	Information security in project management	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.16
ISO 27001	ISO.A5.9	Inventory of information and other associated assets	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.5
ISO 27001	ISO.A5.10	Acceptable use of information and other associated assets	Organizational Controls	● Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.28
ISO 27001	ISO.A5.11	Return of assets	Organizational Controls	● Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.18
ISO 27001	ISO.A5.12	Classification of information	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.26
ISO 27001	ISO.A5.13	Labelling of information	Organizational Controls	● Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.24
ISO 27001	ISO.A5.14	Information transfer	Organizational Controls	● Non-Compliant	High	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.13
ISO 27001	ISO.A5.15	Access control	Organizational Controls	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.22
ISO 27001	ISO.A5.16	Identity management	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.27
ISO 27001	ISO.A5.17	Authentication information	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.8
ISO 27001	ISO.A5.18	Access rights	Organizational Controls	● Non-Compliant	Critical	Approved · Priya Sharma, 24 Sep 2026	access-review-export.xlsx v1, Sheet 'Leavers', rows 2-15
ISO 27001	ISO.A5.19	Information security in supplier relationships	Organizational Controls	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.2
ISO 27001	ISO.A5.20	Addressing information security within supplier agreements	Organizational Controls	● Non-Compliant	High	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.24
ISO 27001	ISO.A5.21	Managing information security in the ICT supply chain	Organizational Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.13
ISO 27001	ISO.A5.22	Monitoring, review and change management of supplier services	Organizational Controls	● Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.8

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A5.23	Information security for use of cloud services	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.17
ISO 27001	ISO.A5.24	Information security incident management planning and preparation	Organizational Controls	● Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A5.25	Assessment and decision on information security events	Organizational Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.14
ISO 27001	ISO.A5.26	Response to information security incidents	Organizational Controls	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.30
ISO 27001	ISO.A5.27	Learning from information security incidents	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.4
ISO 27001	ISO.A5.28	Collection of evidence	Organizational Controls	● Non-Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.16
ISO 27001	ISO.A5.29	Information security during disruption	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.7
ISO 27001	ISO.A5.30	ICT readiness for business continuity	Organizational Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	bcp-2024.pdf v1, whole
ISO 27001	ISO.A5.31	Legal, statutory, regulatory and contractual requirements	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.27
ISO 27001	ISO.A5.32	Intellectual property rights	Organizational Controls	● Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.23
ISO 27001	ISO.A5.33	Protection of records	Organizational Controls	● Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A5.34	Privacy and protection of personal information	Organizational Controls	● Partially Compliant	High	Edited · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.18
ISO 27001	ISO.A5.35	Independent review of information security	Organizational Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.28
ISO 27001	ISO.A5.36	Compliance with policies, rules and standards	Organizational Controls	● Insufficient Evidence	Medium	Edited · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A5.37	Documented operating procedures	Organizational Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.10
ISO 27001	ISO.A6.1	Screening	People Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.25
ISO 27001	ISO.A6.2	Terms and conditions of employment	People Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.28
ISO 27001	ISO.A6.3	Information security awareness, education and training	People Controls	● Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A6.4	Disciplinary process	People Controls	● Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.29
ISO 27001	ISO.A6.5	Responsibilities after termination or change of employment	People Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.26
ISO 27001	ISO.A6.6	Confidentiality or non-disclosure agreements	People Controls	● Non-Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.21

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A6.7	Remote working	People Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.23
ISO 27001	ISO.A6.8	Information security event reporting	People Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.30
ISO 27001	ISO.A8.1	User endpoint devices	Technological Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.3
ISO 27001	ISO.A8.2	Privileged access rights	Technological Controls	● Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.26
ISO 27001	ISO.A8.3	Information access restriction	Technological Controls	● Insufficient Evidence	High	Edited · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.4	Access to source code	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.24
ISO 27001	ISO.A8.5	Secure authentication	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.18
ISO 27001	ISO.A8.6	Capacity management	Technological Controls	● Not Applicable	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.19
ISO 27001	ISO.A8.7	Protection against malware	Technological Controls	● Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.8	Management of technical vulnerabilities	Technological Controls	● Non-Compliant	Critical	Approved · Priya Sharma, 24 Sep 2026	vuln-scan-summary.pdf v1, p.2
ISO 27001	ISO.A8.9	Configuration management	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.4
ISO 27001	ISO.A8.10	Information deletion	Technological Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.23
ISO 27001	ISO.A8.11	Data masking	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.24
ISO 27001	ISO.A8.12	Data leakage prevention	Technological Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.30
ISO 27001	ISO.A8.13	Information backup	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.14
ISO 27001	ISO.A8.14	Redundancy of information processing facilities	Technological Controls	● Insufficient Evidence	Medium	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.15	Logging	Technological Controls	● Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.18
ISO 27001	ISO.A8.16	Monitoring activities	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.12
ISO 27001	ISO.A8.17	Clock synchronization	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.19
ISO 27001	ISO.A8.18	Use of privileged utility programs	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.12
ISO 27001	ISO.A8.19	Installation of software on operational systems	Technological Controls	● Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.5

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A8.20	Networks security	Technological Controls	Not Applicable	Critical	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.4
ISO 27001	ISO.A8.21	Security of network services	Technological Controls	Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.10
ISO 27001	ISO.A8.22	Segregation of networks	Technological Controls	Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.14
ISO 27001	ISO.A8.23	Web filtering	Technological Controls	Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.24
ISO 27001	ISO.A8.24	Use of cryptography	Technological Controls	Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.15
ISO 27001	ISO.A8.25	Secure development life cycle	Technological Controls	Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.26	Application security requirements	Technological Controls	Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.4
ISO 27001	ISO.A8.27	Secure system architecture and engineering principles	Technological Controls	Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.29
ISO 27001	ISO.A8.28	Secure coding	Technological Controls	Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.10
ISO 27001	ISO.A8.29	Security testing in development and acceptance	Technological Controls	Partially Compliant	Medium	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.5
ISO 27001	ISO.A8.30	Outsourced development	Technological Controls	Not Applicable	Medium	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.8
ISO 27001	ISO.A8.31	Separation of development, test and production environments	Technological Controls	Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.32	Change management	Technological Controls	Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.18
ISO 27001	ISO.A8.33	Test information	Technological Controls	Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.10
ISO 27001	ISO.A8.34	Protection of information systems during audit testing	Technological Controls	Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.18

A3 · Evidence register

Document	Version	Added	SHA-256	Cited
access-control-policy.pdf	v2	01 Jul 2026	cd072fd1a9b9	Yes
access-review-export.xlsx	v1	02 Jul 2026	03c3beb9183c	Yes
bcp-2024.pdf	v1	03 Jul 2026	5a83eec521a9	Yes
data-retention-policy.pdf	v1	04 Jul 2026	a159d6175aaa	Yes
incident-response-plan.docx	v2	05 Jul 2026	154f0237f3ea	Yes
isms-manual.pdf	v4	06 Jul 2026	9d25772e52dd	Yes
privacy-policy.pdf	v3	07 Jul 2026	b582f7695b7d	Yes
questionnaire-response.pdf	v1	08 Jul 2026	7bd7980b0a2b	Yes
vendor-contracts-index.xlsx	v2	09 Jul 2026	b231220b5006	Yes
vuln-scan-summary.pdf	v1	01 Jul 2026	3fec5195e1c5	Yes
board-minutes-q1.pdf	v1	02 Jul 2026	72466e7676a1	No

A4 · Statement of Applicability (ISO 27001 2022, 93 controls)

Theme	Implemented	Partially implemented	Not implemented	Not determined	Not applicable	Not assessed
Organizational Controls	15	14	4	4	·	·
People Controls	3	3	1	1	·	·
Physical Controls	·	·	·	·	·	14
Technological Controls	15	10	1	5	3	·

Excluded controls

Control	Justification
Annex A.8.6 Capacity management	Not relevant to the cloud-only operating model.
Annex A.8.20 Networks security	Not relevant to the cloud-only operating model.
Annex A.8.30 Outsourced development	No on-premises development; all development is outsourced under contract.

14 Annex A control(s) were outside the scope of this assessment. Their applicability has not been determined; the organization must decide it before relying on this statement. 90 control(s) have no recorded justification. The full 93-control statement, with a justification column to complete, is in the workbook.